

LAB 02 SEGURIDAD



Estudiante: Emmanuel Aristov
Docente: Jorge Martinez



INCIDENTES

SOFTWARE

02/11

ETERNALBLUE (CVE-2017-0144)





¿QUE PASÓ?

Es una vulnerabilidad crítica de ejecución remota de código (RCE) en Windows que afecta al protocolo SMBv1 (Server Message Block), usado para compartir archivos en red.

Básicamente: un atacante podía ejecutar código en otra máquina sin autenticarse, solo enviando paquetes especialmente diseñados.

¿CUANDO PASÓ?

- Antes de 2017: la vulnerabilidad era conocida y usada en secreto por la NSA (U.S. National Security Agency).
- 14 marzo 2017: Microsoft lanza el parche MS17-010.
- 14 abril 2017: el grupo Shadow Brokers filtra el exploit "EternalBlue".
- ★ 12 mayo 2017: ataque masivo WannaCry usando esta vulnerabilidad.



SMBv1 (Server Message Block versión 1) es el protocolo de red original, creado en los años 80, para compartir archivos e impresoras en Windows. Es altamente inseguro y obsoleto

Afectaba principalmente sistemas

Windows con SMBv1 habilitado:

- Windows Vista
- Windows 7
- Windows 8.1
- Windows 10
- Windows Server (2008, 2012, 2016)

DISPOSITIVOS AFECTADOS

DETALLES TECNICOS

La vulnerabilidad se debía a un problema en cómo SMBv1
manejaba datos:

Mala validación de paquetes SMB

Unidad de datos: Es la
información estructurada que
se envía entre un cliente (ej. tu
PC) y un servidor (ej. un NAS)

Error en el manejo de memoria (buffer overflow)

Procesamiento incorrecto de longitudes de datos



Esto permitió

Enviar paquetes maliciosos
Provocar corrupción de memoria
Ejecutar código remoto con privilegios altos



WannaCry es un ataque de ransomware dirigido a vulnerabilidades sin parches en el protocolo de bloqueo de mensajes (SMB) del servidor de Windows.

¿COMO AFECTÓ AL MUNDO?

El exploit se volvió extremadamente peligroso porque:
Era wormable (se propagaba solo por red)
No requería usuario ni credenciales
Se usó en ataques masivos:

Ejemplos:

WannaCry (2017) → afectó hospitales, empresas y gobiernos
NotPetya (2017) → daños de miles de millones de dólares

¿SOLUCIÓN?

Tuvo solución oficial
Parche: MS17-010 (marzo 2017)
Luego Microsoft lanzó parches incluso para sistemas obsoletos tras WannaCry



INCIDENTES SOFTWARE

07/11

CVE-2014-0160 (HEARTBLEED)



¿QUE PASÓ?

Es una vulnerabilidad crítica en la biblioteca criptográfica OpenSSL que permitía a un atacante leer memoria del servidor o cliente sin autenticación.

En resumen: podías “espiar” partes de la memoria de un sistema remoto.



OpenSSL es una biblioteca de software de código abierto y una herramienta de línea de comandos esencial para la seguridad en redes. Implementa los protocolos SSL (Secure Sockets Layer) y TLS (Transport Layer Security), permitiendo cifrar comunicaciones (HTTPS), generar claves privadas, crear certificados X.509 y gestionar operaciones criptográficas en servidores web y aplicaciones.

¿CUANDO PASÓ?

- 2011: se introduce el bug en OpenSSL
- 7 de abril de 2014: se hace pública la vulnerabilidad
- ⚠ Durante años estuvo explotable sin ser detectada



Afectaba a cualquier sistema que usara versiones vulnerables de OpenSSL:

- Servidores web (Apache, Nginx, etc.)
- Servicios HTTPS
- VPNs
- Correos electrónicos (SMTP, IMAP con TLS)
- Aplicaciones que usan TLS/SSL

En resumen: gran parte de Internet estaba en riesgo.

DISPOSITIVOS AFECTADOS



DETALLES TECNICOS

El problema estaba en la extensión Heartbeat del protocolo TLS.

No se validaban el tamaño de datos devueltos.

Flujo Legítimo	Flujo de Ataque (Heartbleed)
Cliente: "Aquí hay 4 bytes, devuélveme 4".	Atacante: "Aquí hay 1 byte, devuélveme 64 KB".
Servidor: Lee 4 bytes de memoria y responde.	Servidor: Lee 64 KB de memoria y responde.
Resultado: Conexión verificada.	Resultado: Exposición de memoria del sistema.



Un certificado SSL
(Secure Sockets Layer)
es un archivo de datos
digital instalado en un
servidor web que cifra la
información
intercambiada entre el
navegador del usuario y
el sitio, garantizando
privacidad y seguridad

¿COMO AFECTÓ AL MUNDO?

No dejaba rastros (ataque silencioso)

No requería autenticación

Permitía robar claves privadas, comprometiendo HTTPS

Consecuencia grave:

Incluso después de parchear, había que:

cambiar certificados SSL

regenerar claves

resetear contraseñas

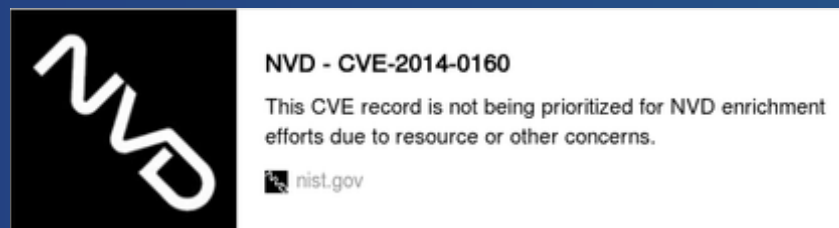
¿SOLUCIÓN?

Tuvo solución oficial

Versión corregida: OpenSSL 1.0.1g (abril 2014)



WEBGRAFÍA



<https://cve.mitre.org/cgi->

[bin/cvename.cgi?name=CVE-2014-0160](https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2014-0160)

<https://heartbleed.com>